ONCOPHARMA — Plano Mestre de Produto e Desenvolvimento (v1.0)

Data: 10/10/2026

Estado: especificação inicial para protótipo com dados sintéticos; não é software clínico validado.

1. Visão

Uma plataforma oncológica para conectar a experiência do paciente ao prontuário e apoiar equipes de farmácia, medicina e enfermagem com resumos rastreáveis, avaliação pré-ciclo, identificação de toxicidades, sugestões baseadas em diretrizes e acompanhamento das intervenções. Não prescreve, não libera ciclos nem substitui decisões profissionais.

2. Produtos e perfis

- ONCOPHARMA Care: interface PWA acessível para paciente e cuidador autorizado; check-in de sintomas, orientações institucionais, medicamentos prescritos, consultas e contato com equipe.
- ONCOPHARMA Intelligence: painel para farmacêutico, médico e enfermagem; fila de pacientes, timeline, revisão pré-ciclo, alertas e intervenções. Permissões diferenciadas por papel.
- ONCOPHARMA Admin: configuração institucional, protocolos versionados, usuários, limiares de triagem e integração.

3. Fluxo principal ponta a ponta

1. Paciente registra sintoma ou hospital disponibiliza novo resultado/evolução.

2. Conector autorizado importa os eventos, identifica o paciente e preserva proveniência, unidade e timestamp.

3. Regras clínicas versionadas classificam condições que requerem ação, com tratamento explícito de dado ausente ou contraditório.

4. IA sumariza e sugere hipóteses a verificar, vinculadas a registros e diretrizes aprovadas, sem inventar achados.

5. Central multiprofissional cria pendência com responsável, prazo institucional, criticidade e estado.

6. Profissional confirma/rejeita/solicita dados, registra justificativa e eventual encaminhamento.

7. Acompanhamento de sintomas e resposta; retorno ao prontuário somente com interface homologada, autenticação, validação e assinatura apropriada.

4. Primeira entrega (MVP demonstrativo, sem pacientes reais)

Paciente

- Check-in em menos de 1 minuto para casos simples, uma pergunta por tela, botões grandes, leitura por voz opcional e texto ampliável.
- Sintomas iniciais: náusea/vômito, diarreia, febre/calafrios, dor, fadiga, parestesia.
- Linguagem simples e botão de ajuda sempre disponível; sinais graves orientam atendimento apropriado sem depender de monitoramento do aplicativo.
- Histórico e acesso do cuidador apenas simulado no MVP.

Profissional

- Lista de pacientes sintéticos por prioridade e ciclo.

- Ficha única com cronologia de sintomas, exames, medicações, protocolo e notas por profissão.
- Resumo pré-ciclo com origem de cada dado, data, ausências e conflitos.
- Cartões de achados: sintoma/risco identificado → evidência → hipótese → recomendação de avaliação → profissional responsável → decisão → resultado.
- Registro de intervenções e exportação demonstrativa.

Três cenários de demonstração

A. FOLFOX: parestesia e sensibilidade ao frio → suspeita de neuropatia relacionada a oxaliplatina → revisão profissional.

B. Náusea pós-ciclo: checar profilaxia já prescrita, tolerância oral, sinais de gravidade, fatores de risco e interações → alternativa para avaliação, nunca ordem de administrar ondansetrona automaticamente.

C. Febre >= 38 °C durante quimioterapia → orientação urgente ao paciente e sinalização de alta prioridade; não aguardar aceite interno para orientar busca de atendimento.

5. Interface do painel profissional

- Visão geral: pendências críticas, pacientes do dia, consultas/ciclos e alertas sem revisão.
- Pacientes: busca e filtros por unidade, protocolo, ciclo, nível de risco e profissional.
- Ficha do paciente: resumo, cronologia, protocolos, medicamentos, exames, sintomas, notas e intervenções.
- Avaliação pré-ciclo: checklist verificável de identificação/ciclo, protocolo, prescrição, parâmetros laboratoriais, toxicidades anteriores, medidas de suporte, exames ausentes e responsável pela validação.
- Central de alertas: evidência e grau de certeza, ação recomendada, atribuição, prazo e status; evitar avalanche de alertas.
- Copilot: perguntas sobre dados apresentados, com links para fontes, sem modificar prontuário nem fornecer prescrição automática.
- Indicadores: alerta útil/falso, tempo até revisão, intervenções aceitas, pendências vencidas e cobertura do check-in.

6. Motor clínico — separação obrigatória

- Regras determinísticas: condições críticas, unidades, comparação laboratorial, cálculos e validação estrutural. Revisão e versionamento por equipe clínica.
- IA de linguagem: extração com indicação de citação, resumo de histórico e elaboração de sugestões não vinculantes.
- Conhecimento: protocolos institucionais aprovados, bibliografia versionada e elegibilidade contextual; nenhum documento externo é automaticamente regra de conduta.
- Segurança: baixa confiança, ausência de referência ou dado incompatível = abstinência e pedido de revisão humana. Monitorar falsos positivos, falsos negativos, omissões e deriva.

7. Integração com hospital (etapas)

0. Conector simulado com dados sintéticos em formato canônico alinhado ao FHIR R4.

1. Importação autorizada de relatórios/extratos estruturados de ambiente de testes.

2. Conector Tasy/MV condicionado a fornecedor, licenças, APIs, contrato, aprovação do hospital e homologação.

3. Escrita supervisionada de intervenções no prontuário apenas quando formalmente habilitada.

Eventos/fonte: pacientes, encontros, pedidos e administrações de medicamentos, observações laboratoriais, evoluções e protocolos; modelo de permissões e identificação de paciente entre sistemas é parte central do projeto.

8. Modelo lógico de dados mínimo

Organization, User, Role, Patient, CaregiverGrant, Encounter, TreatmentPlan, Cycle, MedicationOrder, MedicationAdministration, LabResult, ClinicalNote, SymptomReport, EvidenceLink, ClinicalFinding, Recommendation, Task, ProfessionalReview, Intervention, FollowUp, ProtocolVersion, AuditEvent, IntegrationEvent.

Campos transversais: id, patientId, sourceSystem, sourceRecordId, observedAt, recordedAt, author/role, dataQuality, version e auditTrail conforme tipo.

9. Arquitetura inicial sugerida

- Frontend web/PWA responsivo: Next.js/React; interfaces distintas por perfil.
- Backend: NestJS (ou FastAPI, escolha uma stack principal); PostgreSQL; fila de eventos e trabalhos assíncronos.
- Adaptadores de integração isolados do domínio clínico; HL7 FHIR R4 como contrato interno inicial onde aplicável.
- Serviço de IA separado com recuperação de fontes aprovadas (RAG), controle de versões de prompt/modelo e trilhas de auditoria.
- Autenticação institucional, autorização por papel/unidade, criptografia em trânsito e em repouso, logs, backup, retenção e resposta a incidentes.
- Sem dados reais em ambientes de protótipo e sem usar conteúdo clínico para treino de modelos sem base legal/contratual apropriada.

10. Requisitos antes de piloto clínico

- Governança do hospital, LGPD: controlador/operador, finalidade, base legal, DPIA/RIPD conforme avaliação, acordos e privacidade do paciente.
- Análise de classificação regulatória do software, plano de qualidade/risco e validação clínica conforme enquadramento aplicável.
- Aprovação das regras e textos por responsáveis clínicos; plano de contingência, suporte 24h somente se efetivamente contratado e operado.
- Integração autorizada e testada; ensaios de identidade do paciente e reconciliação de dados.
- Testes de acessibilidade com idosos, tela pequena, zoom, leitores de tela e cuidador; avaliação de impacto e desempenho em cenários de alto risco.

11. Roadmap por marcos (sem prazos inventados)

M0 — Definição: visão, perfis, critérios clínicos, escopo do MVP e protótipo existente revisado.

M1 — Experiência do paciente: check-in, histórico, ajuda, acessibilidade, testes de UX com dados fictícios.

M2 — Painel profissional: fila, ficha, timeline, revisão pré-ciclo e intervenções simuladas.

M3 — Motor de regras: regras conservadoras, explicações, suíte de casos, controle de versões.

M4 — IA rastreável: resumo com citação para fontes, abstenção, avaliação de erros e revisão humana.

M5 — Integração simulada: importação de dados sintéticos, reconciliação e logs de eventos.

M6 — Piloto institucional: só após avaliação de segurança, governança, autorização, validação e contrato.

M7 — Expansão: protocolos adicionais, farmacogenética, estabilidade/administração, analytics e conectores adicionais.

12. Critérios de aceitação do MVP

- Check-in completo e acessível em 360×740 e 390×844, zoom e letras ampliadas; nenhum botão coberto.
- Casos críticos demonstrativos apresentam orientação de urgência independentemente da IA.

- Resumos exibem fonte, data e status da informação; ausências não são interpretadas como negativas.
- Cada sugestão permite aceitar, rejeitar ou pedir informações com justificativa, profissional e trilha.
- Nenhuma ação altera prescrição, dose, ciclo ou prontuário de produção.
- Testes automatizados de regressão para os três cenários, dados contraditórios, dados ausentes e identidades não conciliadas.

13. Próxima tarefa concreta

Criar o M1 + esqueleto de M2 em protótipo navegável, reaproveitando ONCOPHARMA-Care.html, com dados fictícios de 3 pacientes e com demonstração completa do fluxo FOLFOX/neuropatia. Separar a experiência paciente/profissional, preparar interface de eventos e testes de acessibilidade. A eventual integração real ficará bloqueada até validação institucional.

ONCOPHARMA — Plano de Engenharia de Produção v2.0

Data: 10/10/2026 | Estado: especificação de produto real, ainda não liberado para assistência clínica

Decisão de produto

Construir uma plataforma única multiusuário, multiunidade e preparada para integração hospitalar, com quatro experiências: Care (paciente/cuidador), Clinical (farmácia/medicina/enfermagem), Intelligence (apoio à decisão) e Admin (governança). O código e o modelo de dados serão de produção desde o início. Somente 1–2 pacientes sintéticos serão usados em desenvolvimento e homologação, jamais misturados a pacientes reais.

Stack proposta

- Frontend: Next.js + TypeScript, PWA responsiva, WCAG 2.2 AA como meta, testes com idosos e tecnologias assistivas.
- Backend: NestJS + TypeScript, API versionada com OpenAPI, filas assíncronas para integrações e alertas.
- Dados: PostgreSQL com migrações e isolamento por organização, Redis para filas/cache sem usar como prontuário de referência, armazenamento de objetos privado para anexos.
- Identidade: provedor OIDC/OAuth2 com MFA obrigatório para profissionais; autenticação adaptada para pacientes; RBAC + ABAC por vínculo assistencial e organização.
- Interoperabilidade: adaptadores FHIR R4/HL7 v2/API proprietária com mapeamentos e trilha de proveniência. Tasy/MV só após contrato e autorização.
- IA: serviço isolado com RAG, referências de fontes versionadas, extração estruturada e supervisão; motor determinístico de regras para segurança clínica, nunca LLM isolado.
- Infraestrutura: ambientes separados dev, homologação e produção; CI/CD, testes, observabilidade, backup criptografado, recuperação testada e gestão de segredos.

Domínios e entidades essenciais

Organization, Facility, User, Role, CareTeam, Patient, PatientIdentifier, Consent, CaregiverAccess, Encounter, Diagnosis, CancerStage, Biomarker, Regimen, RegimenVersion, TreatmentCycle, MedicationOrder, MedicationAdministration, MedicationStatement, AllergyIntolerance, LaboratoryResult, VitalSign, SymptomReport, QuestionnaireResponse, ClinicalNote, ClinicalSource, Alert, ClinicalSuggestion, GuidelineReference, Intervention, ReviewDecision, Task, NotificationDelivery, AuditEvent, IntegrationConnection, ImportJob.

Todas as entidades clínicas devem ter ID imutável, organização, paciente, timestamps, autor/origem, versão e regras de retenção.

Fluxo clínico

1. Paciente informa sintomas com linguagem acessível; eventos de urgência exibem orientação imediata, sem depender de conectividade ou IA.

2. Sistema vincula relato ao ciclo, protocolo, exames, prescrições e registros clínicos autorizados.

3. Regras clínicas identificam riscos e dados ausentes; IA propõe hipóteses de correlação com evidências e grau de incerteza.

4. Profissional vê origem de cada achado e sugestões de avaliação/conduta condicionadas ao protocolo institucional, alergias, interações e medicações já administradas.

5. Profissional aceita, modifica, rejeita ou encaminha, registrando justificativa, responsável e prazo.

6. Sistema acompanha confirmação de recebimento, reavaliação, resolução e síntese pré-ciclo. Não prescreve nem altera tratamentos automaticamente.

Segurança e governança

- Dados de saúde: LGPD, bases legais definidas com encarregado/jurídico, contratos com operadores, análise de impacto, finalidade e minimização.
- Criptografia em trânsito e repouso, gestão de chaves, trilhas imutáveis, controle de acesso por necessidade, logs sem PHI desnecessária.
- Protocolos clínicos versionados, autoria/revisão/aprovação institucional, data de vigência e rollback.
- Gestão de risco clínico, testes de sensibilidade/especificidade e fadiga de alertas, revisão de casos adversos, política de incidentes.
- Avaliação de enquadramento como software médico (SaMD) na Anvisa antes do uso assistencial; verificação das demais exigências aplicáveis.
- Alertas críticos: instrução imediata ao paciente, canal humano de atendimento e regras de escalonamento configuradas; sem alegar monitoramento 24h sem operação real.

Dados de teste e transição

- Ambientes DEV e HOMOLOGAÇÃO: dois pacientes inteiramente sintéticos (FOLFOX/neuropatia; AC-T/náusea e possível febre), profissionais sintéticos, exames e evoluções simulados.
- Produção: banco e credenciais separados, criado vazio; jamais promover banco de homologação para produção.
- Testes E2E verificam segregação e impedem importação de dados sintéticos no ambiente produtivo.
- Processo de limpeza: apagar/resetar apenas dados sintéticos em DEV/HOMOLOGAÇÃO por migração ou seed reversível, preservar esquema, regras, protocolos e código; produzir relatório de limpeza.
- Nenhuma exclusão em massa de dados reais ou de logs de auditoria em produção.

Backlog em ordem

Sprint 0 — Fundação: monorepo, design system, arquitetura, modelo de ameaça, migrations, CI/CD, autenticação e permissões.

Sprint 1 — Núcleo clínico: organizações, profissionais, pacientes, equipes, encontros, tratamentos, ciclos, exames, medicamentos, notas e fontes.

Sprint 2 — Care: check-in acessível, perguntas condicionais, cuidador, orientações urgentes, consentimento e histórico.

Sprint 3 — Clinical: lista de pacientes, linha do tempo, caixa de entrada de alertas, revisão profissional e registro de intervenção.

Sprint 4 — Regras clínicas: biblioteca versionada, correlação determinística, testes clínicos e regras de escalonamento.

Sprint 5 — Intelligence: resumos com proveniência, RAG, sugestões justificadas, incerteza e aprovação humana.

Sprint 6 — Integração: servidor FHIR simulado, mapeamento, sincronização idempotente, tratamento de conflitos e testes de falhas.

Sprint 7 — Preparação para piloto: segurança, avaliação clínica, avaliação regulatória, homologação institucional e observabilidade.

Critérios de aceite para a primeira versão utilizável

- Dois perfis autenticados e isolados (paciente e farmacêutico) com autorização correta; outros perfis em evolução.
- Um paciente relata sintoma; o profissional vê evento e origem, recebe prioridade, registra avaliação e acompanha status.

- Um segundo paciente testa cenário de alerta urgente sem depender da IA.
- Dados persistem no backend, com migrações, auditoria e backup; nenhuma PHI real em desenvolvimento.
- Testes automatizados de acesso indevido, duplicidade, reconciliação, falha de rede, teclado/leitor de tela e telas 360x740 e 390x844.
- Ambiente de produção nasce vazio e só é ativado após as aprovações necessárias.

Decisões abertas

Hospedagem e residência dos dados; instituição parceira; políticas clínicas e responsável pela aprovação; modelo de operação de alertas; provedor de identidade; custos e equipe; versão/interface dos sistemas hospitalares. Nenhuma dessas decisões impede iniciar a fundação técnica.

ONCOPHARMA

PLANO DIRETOR DO PRODUTO

Care | Clinical | Intelligence | Admin

Versão 3.0 • 10 de outubro de 2026

Documento mestre de requisitos, identidade visual, fluxos clínicos, arquitetura e critérios de qualidade.



Referência conceitual da identidade aprovada; arte final vetorial pendente.

STATUS | Planejamento de produto real; não homologado para uso assistencial

> ***Propósito deste documento:*** *ser a fonte única de verdade sobre escopo, identidade visual, funcionamento, regras clínicas, arquitetura, prioridades e critérios de entrega. Decisões novas devem atualizar este arquivo e o registro de decisões, nunca ficar apenas dispersas em conversas.*

0. RESUMO EXECUTIVO

O ONCOPHARMA será uma plataforma PWA de acompanhamento oncológico com duas experiências de usuário — **ONCOPHARMA Care** (paciente/cuidador) e **ONCOPHARMA Clinical** (equipe multiprofissional) — apoiadas por serviços internos de **Intelligence** (correlação e apoio à decisão) e **Admin** (governança, usuários, protocolos e integrações). O diferencial é transformar dados fragmentados em **avaliações clínicas acionáveis, justificadas e rastreáveis**, sem prescrever, alterar terapia ou encerrar alertas automaticamente.

Produto real desde a fundação: backend, banco, autenticação, controle de acesso, versionamento, testes e ambientes segregados. Os dois pacientes usados na implementação serão inteiramente sintéticos; produção nasce vazia. A implantação clínica exige validação, segurança, enquadramento regulatório e operação assistencial definidos.

1. DECISÕES APROVADAS E LIMITES

ID	Decisão	Situação
D-001	Uma plataforma PWA responsiva, com código e infraestrutura de produção	Aprovada
D-002	Duas interfaces: Care simples e Clinical multiprofissional	Aprovada
D-003	Marca principal ONCOPHARMA, sub-marcas Care e Clinical	Aprovada
D-004	Identidade verde-esmeralda, azul-petróleo e dourado, fundos escuros e versões claras acessíveis	Direção aprovada; arte final vetorial pendente
D-005	IA explica correlações e propõe opções fundamentadas; decisão humana obrigatória	Aprovada
D-006	1–2 pacientes sintéticos em DEV/HML; produção sem dados de teste	Aprovada
D-007	Integração Tasy/MV/FHIR apenas mediante autorização, contrato e validação técnica	Princípio aprovado
D-008	Hospedagem, provedor de login, instituição-piloto e modelo de operação de alertas	Em aberto

Fora de escopo da primeira liberação: prescrição automática, liberação de ciclos, mudança de doses sem profissional, atendimento emergencial 24h sem equipe real, diagnósticos autônomos e integração não autorizada com prontuários.

2. IDENTIDADE VISUAL E SISTEMA DE DESIGN

2.1 Marca e conceito

- **ONCOPHARMA:** marca-mãe de tecnologia, oncologia, inteligência clínica e cuidado humano.
- **Care:** símbolo de **casa** + **acolhimento** + **pessoas/coração**; comunicar segurança e simplicidade, sem infantilização do idoso.
- **Clinical:** símbolo de **bolsa de infusão oncológica** + **referência clínica**, com desenho estilizado; não confundir bolsa de quimioterapia com bolsa de sangue, nem sugerir que todo tratamento é infusional.

- **Intelligence:** nome de módulo interno; não precisa de terceira marca de consumo nesta etapa.
- **Assinatura institucional proposta:** “Inteligência para um cuidado mais seguro”. Care pode usar “Um passo de cada vez. Juntos no cuidado.”
- A arte aprovada na conversa é uma **referência conceitual raster**, não um arquivo vetorial final. Criar logotipos vetoriais SVG, versões horizontal/vertical, ícone monocromático, favicon, splash e manual de marca antes do lançamento.
- **Não aplicar o símbolo ®** sem confirmação de registro da marca; verificar disponibilidade de marca e domínio antes de uso comercial.

2.2 Tokens visuais iniciais (sujeitos à extração da arte final)

Token	HEX proposto	Uso
brand.deepTeal	#063F3B	Marca, navegação Care, fundos escuros
brand.emerald	#15735D	Ações principais Care e sucesso não clínico
brand.navy	#0A344A	Clinical, navegação e painéis técnicos
brand.gold	#D7A858	Acentos e detalhes; nunca único indicador de prioridade
brand.mint	#B9E1D0	Apoio e superfícies suaves
neutral.canvas	#F5F8F7	Fundo claro acessível
neutral.ink	#152C32	Texto em fundo claro
danger	#B42318	Alertas críticos, sempre com texto/ícone

Regras de interface: contraste WCAG 2.2 AA como meta, alvos de toque amplos, sem texto sobre gradientes de baixo contraste, componentes reutilizáveis, estados de foco/erro/carregamento/vazio e modo escuro/claro testados. As cores clínicas de gravidade não se confundem com a paleta de marca.

2.3 Diretrizes por público

Care	Clinical
Linguagem cotidiana; um objetivo por tela	Densidade de dados controlada e filtros
Botões grandes, alto contraste e leitura fácil	Visão longitudinal, origem dos dados e trilha de decisão
Perguntas curtas, resposta por toque, leitura por voz opcional	Tabelas, indicadores, tarefas e alertas priorizados
Sempre explicar o próximo passo	Mostrar incerteza, dados faltantes e referência clínica
Sem dose ou automedicação sugerida ao paciente	Sugestões condicionais apenas para revisão habilitada

3. PERSONAS, PAPÉIS E PERMISSÕES

Paciente: relata sintomas, consulta orientações aprovadas, vê sua própria jornada e pode conceder acesso ao cuidador. **Cuidador:** vê somente o escopo autorizado e revogável. **Farmacêutico:** reconciliação, validação farmacoterapêutica, intervenções e monitoramento. **Enfermagem:** registro de sinais, administração, evolução e triagem conforme competências. **Médico:** decisões diagnósticas e terapêuticas e prescrição. **Gestor clínico:** filas, indicadores, protocolos e auditoria. **Administrador técnico:** usuários, infraestrutura e integração; não ganha acesso irrestrito a dados clínicos por padrão.

Recurso	Paciente	Cuidador	Farmacêutico	Enfermagem	Médico	Admin
Registrar sintomas	Próprio	Conforme autorização	Consulta	Consulta	Consulta	Não
Ver histórico clínico	Recorte permitido	Recorte autorizado	Vínculo assistencial	Vínculo assistencial	Vínculo assistencial	Não por padrão
Revisar alerta	Não	Não	Sim	Conforme atribuição	Sim	Não
Propor intervenção farmacêutica	Não	Não	Sim	Não	Conforme atribuição	Não

Prescrever/ alterar terapia	Não	Não	Não via sugestão de IA	Não	Conforme habilitação e sistema oficial	Não
Aprovar protocolo institucional	Não	Não	Papel designado	Papel designado	Papel designado	Gestão de fluxo, não aprovação clínica

Controle de acesso: RBAC + regras contextuais ABAC (organização, unidade, equipe assistencial, consentimentos, finalidade e emergência auditada). MFA para profissionais, sessões expiráveis e segregação por instituição.

4. MAPA DE PRODUTO E NAVEGAÇÃO

4.1 ONCOPHARMA Care

1. **Boas-vindas e acesso:** identificação segura, consentimentos, preferência de acessibilidade, cuidador.
2. **Início:** “Como você está hoje?”, próximo ciclo/consulta, lembretes, acesso visível a ajuda.
3. **Registrar sintoma:** questionário adaptativo; duração, intensidade, início, sinais de alerta; confirmação do registro.
4. **Minha jornada:** tratamento/ciclos e histórico de sintomas em linguagem simples; dados sincronizados autorizados.
5. **Meus medicamentos:** exibir prescrição validada, horários e orientações aprovadas; registrar adesão relatada, sem alterar dose.
6. **Mensagens e orientações:** apenas canal institucional real, com horários e expectativa de resposta explícitos.
7. **Preciso de ajuda:** orientação de urgência imediata para sinais críticos; contatos reais configurados, sem falsa promessa de monitoramento.
8. **Cuidador e privacidade:** autorização granular, prazo, revogação, histórico de acessos.

4.2 ONCOPHARMA Clinical

1. **Painel:** pacientes vinculados, fila de alertas, tarefas, pré-ciclos, pendências de revisão.
2. **Pacientes:** busca com identificação segura e filtros por serviço, protocolo, ciclo, gravidade e pendência.
3. **Prontuário longitudinal:** diagnóstico, estadiamento, biomarcadores, alergias, comorbidades, medicamentos, exames, prescrições, administrações, evoluções, sintomas e fontes.
4. **Avaliação pré-ciclo:** checklist com dados disponíveis/ausentes, evolução de toxicidades, parâmetros de protocolo e parecer do profissional.
5. **Inteligência Clínica:** hipóteses de associação, justificativas, alternativas condicionais, diretrizes e evidências, contraindicações e lacunas.
6. **Intervenções:** registrar avaliação, aceitação/ajuste/rejeição de sugestão, encaminhamento, responsável, prazo e desfecho.
7. **Protocolos:** versões vigentes, critérios de aplicação, suporte antiemético, segurança da administração e referências.
8. **Indicadores:** adesão ao acompanhamento, tempo até revisão, eventos, intervenções, resolutividade, falsos positivos e qualidade dos dados.
9. **Admin:** profissionais, equipes, permissões, políticas, conectores, trilhas, biblioteca clínica e configurações de serviço.

5. COMPORTAMENTO PADRÃO DE CADA FUNCIONALIDADE

Evento	Entrada	Ação do sistema	Resultado visível	Responsável/registro
Paciente registra sintoma	Questionário	Valida, salva, identifica sinais críticos por regras	Confirmação, orientação segura, status de envio	Paciente; data/hora/origem
Dado hospitalar chega	FHIR/HL7/API autorizada	Autentica, reconcilia paciente, deduplica, normaliza, preserva origem	Linha do tempo atualizada ou erro de integração	Integração; provenance e audit
Possível toxicidade	Sintomas + protocolo + administração + exames	Regras determinísticas, depois correlação explicativa da IA	Alerta, justificativa, evidências e lacunas	Equipe clínica; status aberto
Sugestão de suporte	Sintoma + risco + antieméticos + alergias + exames	Consulta protocolos versionados e restrições	Opções de avaliação, nunca ordem médica automática	Profissional aceita/ajusta/rejeita
Revisão profissional	Alerta ou pré-ciclo	Exige ação explícita e registra justificativa	Plano, encaminhamento, prazo e status	Identidade profissional + trilha
Encaminhamento	Intervenção validada	Cria tarefa, atribui equipe e confirma entrega	Pendente, recebido, em avaliação, resolvido	Destinatário e timestamps
Dados insuficientes	Ausência de exame/medicação/registro	Bloqueia conclusão indevida; solicita verificação	“Não é possível concluir” + dado faltante	Auditoria de incerteza
Alerta crítico	Febre em quimioterapia ou outro sinal de urgência conforme regra aprovada	Orientação imediata ao paciente; escalonamento institucional configurado	Mensagem inequívoca e canal de urgência	Registro e eventual equipe 24h real

5.1 Estados de alerta

Detectado → Aguardando revisão → Em avaliação → Encaminhado → Em acompanhamento → Resolvido; alternativas **Descartado com justificativa** e **Duplicado vinculado**. Escalonamento por SLA institucional, sem encerrar automaticamente por tempo. Registrar tentativas de contato e confirmação de recebimento.

5.2 Exemplo: náusea leve (hipotético)

O sistema coleta início/intensidade, número de episódios de vômito, hidratação, ingestão, risco de desidratação, tempo em relação ao ciclo, esquema emetogênico, profilaxia e resgate prescritos/administrados, alergias, interações, QT prolongado e outros fatores pertinentes. Consulta diretrizes e protocolo local vigentes; pode apresentar **ondansetrona como uma das opções a avaliar quando apropriado**, sem assumir que será suficiente ou segura para qualquer paciente. O profissional verifica necessidade, dose, via, contraindicações e prescrição no sistema oficial. Para o paciente, exibir apenas orientação validada, não recomendação autônoma de medicamento.

5.3 Exemplo: FOLFOX e neuropatia (hipotético)

Cruzar relato de parestesia/sensibilidade ao frio, evolução da enfermagem, datas de administração de oxaliplatina, progressão entre ciclos e critérios de toxicidade; apontar **possível associação**, não causalidade confirmada. Apresentar evidências e solicitar avaliação da equipe; decisões sobre dose/ciclo ficam com responsáveis habilitados.

6. INTELIGÊNCIA CLÍNICA: PRINCÍPIOS TÉCNICOS

Pipeline: coleta autorizada → normalização → validação de completude → regras de segurança → correlação contextual por IA → busca em referências aprovadas (RAG) → verificação estruturada → apresentação ao profissional → decisão e acompanhamento.

- **Regras clínicas determinísticas** são a primeira linha para gatilhos críticos, limites laboratoriais e contraindicações configuradas; LLM não pode suprimir alerta crítico.
- **IA generativa** resume registros e explica possíveis relações, mas nunca deve inventar exame, dose, referência ou resultado; campos ausentes permanecem ausentes.
- Cada sugestão traz: hipótese, confiança/limitações qualitativas, evidências de paciente com origem e horário, referência clínica com versão/data, alternativas e verificações necessárias.
- Não usar uma porcentagem de “confiança” não calibrada como probabilidade clínica.
- Prompts, modelos, regras, protocolos e resultados são versionados; testes de regressão obrigatórios após mudança.
- Avaliar desempenho por cenário, gravidade, sensibilidade, especificidade, PPV, falsos negativos, equidade e fadiga de alertas; manter revisão humana.
- Conteúdo clínico: biblioteca aprovada pela instituição, com revisão periódica e rastreio de mudanças; não tratar pesquisa na internet como protocolo automaticamente vigente.

7. DADOS, INTEGRAÇÃO E FONTE OFICIAL

Prontuário hospitalar é fonte oficial para ordens, evoluções e administrações nele registradas; ONCOPHARMA armazena dados derivados, relatos do paciente, pareceres e trilhas, sem duplicar documentação desnecessariamente. Integrações são preferencialmente bidirecionais apenas quando houver contrato, mapeamento e autorização para escrita; na primeira fase, leitura autorizada e escrita restrita ao próprio ONCOPHARMA.

Entidades nucleares: Organization, Facility, User, Role, CareTeam, Patient, PatientIdentifier, Consent, RelatedPerson/CaregiverAccess, Encounter, Diagnosis, CancerStage, Biomarker, Regimen/Version, TreatmentCycle, MedicationOrder, MedicationAdministration, MedicationStatement, AllergyIntolerance, LabResult, Observation, SymptomReport, QuestionnaireResponse, ClinicalNote, Source/Provenance, Alert, Suggestion, GuidelineReference, Intervention, ReviewDecision, Task, Notification, AuditEvent, IntegrationJob.

Integrações-alvo: FHIR R4 (Patient, Encounter, Observation, Condition, MedicationRequest, MedicationAdministration, AllergyIntolerance, CarePlan, Provenance, AuditEvent etc. conforme perfis acordados), HL7 v2, APIs proprietárias Tasy/MV quando disponíveis. Identificadores, unidades, terminologias, fuso horário, duplicatas, conflitos, erros e reconciliação são requisitos de projeto.

8. SEGURANÇA, PRIVACIDADE E CONFORMIDADE

- LGPD: controlador e operadores definidos, base legal adequada para dados sensíveis, minimização, retenção, direitos, RIPD conforme avaliação, contratos e incidentes.
- Criptografia em trânsito e repouso; chaves/segredos gerenciados; backups restauráveis testados; política de recuperação de desastre.
- Autenticação forte, MFA para equipe, menor privilégio, trilhas auditáveis e revisão de acessos.
- Segregação de ambientes e instituições; logs sem dados clínicos desnecessários; monitoração de disponibilidade e segurança.
- Avaliação formal do enquadramento regulatório aplicável ao software como dispositivo médico (SaMD), inclusive regras Anvisa pertinentes, antes do piloto assistencial.
- Política de segurança do paciente, protocolos revisados por responsáveis clínicos, testes de casos de risco, revisão de incidentes e plano de contingência quando a IA/integração falhar.
- Alertas de urgência requerem fluxo operacional real, responsáveis, horário de cobertura e escalonamento; se não houver cobertura, orientar contato com urgência sem insinuar monitoramento contínuo.

9. ARQUITETURA DE ENGENHARIA

Frontend: Next.js + TypeScript + PWA; design system compartilhado e rotas Care/Clinical com layouts próprios. **Backend:** NestJS + TypeScript, API versionada/OpenAPI, validação e jobs assíncronos. **Banco:** PostgreSQL, migrações e segregação por organização. **Filas/cache:** Redis quando necessário; não como fonte oficial de dados. **Arquivos:** storage privado criptografado. **Identidade:** OIDC/OAuth2 com MFA. **Integrações:** adaptadores FHIR/HL7/API. **IA:** serviço isolado com RAG, auditoria e políticas de dados. **Observabilidade:** métricas, logs, tracing, alertas e relatórios de auditoria. **Entrega:** monorepo, CI/CD, testes automatizados, infraestrutura declarativa, dev/homologação/produção independentes.

Estrutura sugerida do repositório:

```
oncopharma/
  apps/care-web/
  apps/clinical-web/
  apps/admin-web/
  services/api/
  services/clinical-rules/
  services/ai-orchestrator/
  services/integration-gateway/
  packages/design-system/
  packages/domain/
  packages/contracts/
  packages/clinical-content/
  infra/
  docs/architecture/
  docs/product/
  docs/decisions/
  tests/e2e/
```

10. ROADMAP POR ENTREGÁVEIS (SEM PRAZOS INVENTADOS)

Marco	Entrega verificável	Dependência / critério de saída
M0 — Governança	Plano diretor, backlog, design tokens, ADRs, risco inicial	Decisões críticas registradas
M1 — Fundação	Monorepo, CI/CD, ambientes, login, MFA, perfis, banco e migrações	Testes de segurança/acesso e deploy reproduzível
M2 — Núcleo clínico	Paciente, protocolo, ciclo, exames, medicamentos, evoluções e proveniência	Dois pacientes sintéticos persistidos e auditáveis
M3 — Care	Check-in, histórico, ajuda, cuidador, acessibilidade	Testes com usuários e cenários críticos aprovados
M4 — Clinical	Dashboard, prontuário, pré-ciclo, fila, intervenção, tarefas	Fluxo completo de revisão e encaminhamento
M5 — Regras clínicas	Gatilhos, classificação, versionamento e testes	Casos de segurança validados por especialistas
M6 — Intelligence	Resumos e sugestões rastreáveis com RAG	Avaliação clínica offline, controles de alucinação
M7 — Integração	Gateway e simulador FHIR, reconciliação e falhas	Testes de sincronização e origem; integração real só autorizada
M8 — Preparação piloto	Privacidade, segurança, regulação, operação e validação	Aprovação formal antes de dados reais

Primeiro fluxo vertical completo: um paciente sintético registra sintoma no Care → backend salva → regras classificam → Clinical exibe evento e origem → farmacêutico revisa → intervenção/tarefa registrada → paciente vê apenas orientação autorizada → auditoria permite reconstruir toda a sequência.

11. CENÁRIOS DE TESTE E LIMPEZA

- **Paciente sintético A:** FOLFOX, parestesia/sensibilidade ao frio, histórico de ciclos e registro de enfermagem.
- **Paciente sintético B:** AC-T, náusea e cenários separados de febre/sinal crítico; profilaxia antiemética e registro de administração sintéticos.
- DEV e HOMOLOGAÇÃO recebem seeds versionados, dados e credenciais fictícios; **produção nasce com banco vazio**, não por limpeza de dados de teste em ambiente real.
- Reset de testes é idempotente e limitado por ambiente, com confirmação e registro. Preservar esquema, código, conteúdo clínico aprovado e logs exigidos.
- Testar acessos indevidos, duplicatas, perda de rede, latência, alarmes críticos, alteração de protocolos, contraste, leitores de tela, teclado, zoom 200% e aparelhos pequenos.

12. DEFINIÇÃO DE PRONTO (DoD) PARA QUALQUER TELA OU MÓDULO

Uma funcionalidade só será marcada **CONCLUÍDA** se possuir: (1) objetivo e usuário definidos; (2) fluxo feliz e erros documentados; (3) contratos de API e validações; (4) permissões testadas; (5) estados loading/vazio/erro; (6) responsividade e acessibilidade; (7) persistência e auditoria quando aplicável; (8) testes unitários/integrados/E2E; (9) segurança/privacidade revisadas; (10) conteúdo clínico aprovado quando houver; (11) documentação atualizada; (12) aprovação do responsável do produto. Telas bonitas sem backend real não contam como entrega concluída.

13. CONTROLE DE MUDANÇAS — COMO NÃO NOS PERDEREMOS

- **Documento mestre:** este arquivo é a referência de escopo e comportamento.
- **Backlog rastreável:** cada funcionalidade tem ID, prioridade, dependências, critério de aceite e estado.
- **ADRs (Architecture Decision Records):** decisões técnicas com contexto, alternativas e consequências.
- **Matriz de rastreabilidade:** necessidade → tela → regra → API → teste → aprovação.
- **Changelog:** toda mudança importante registra data, autor, motivo, impacto e versão.
- **Versionamento:** 3.0 planejamento; próximas revisões 3.1, 3.2; releases do software terão versões próprias.
- **Não alterar decisões aprovadas silenciosamente:** mudanças de identidade, dados clínicos, fluxo de alertas e autonomia da IA exigem revisão explícita.

13.1 Modelo de ficha de funcionalidade

ID / Nome / Público / Objetivo / Entradas / Fontes / Regras / Estados / Saídas / Quem valida / Segurança / Dependências / Casos de teste / Critérios de aceite / Status.

13.2 Modelo de registro de decisão

ADR-ID | Data | Contexto | Alternativas | Decisão | Justificativa | Impacto | Responsável | Estado.

14. RISCOS, RESPONSÁVEIS E DECISÕES PENDENTES

Tema	Risco se ignorado	Próxima decisão

Operação de alertas	Falsa expectativa de atendimento imediato	Quem monitora, quando e com qual SLA?
Responsabilidade clínica	Sugestões sem validação institucional	Comitê clínico e aprovadores de protocolos
Regulação	Implantação inadequada de SaMD	Avaliação regulatória formal
Integração hospitalar	Acesso indevido/inconsistência de dados	Instituição e fornecedores parceiros
Hospedagem	Segurança, custos e residência de dados	Provedor, região, contratos e orçamento
Marca	Uso indevido de ® e conflito de registro	Pesquisa de marca/domínio e arte final SVG
Modelo de negócio	Escopo e custos sem sustentabilidade	Piloto B2B hospitalar? licenciamento?
Equipe	Desenvolvimento sem revisão especializada	Papéis técnicos, clínicos, segurança e jurídico

15. PRÓXIMAS AÇÕES CONCRETAS

1. Congelar esta **baseline v3.0** como ponto de partida, sujeita a revisão controlada.
2. Criar **design system v0.1** e logotipos finais vetoriais, com variações Care/Clinical, favicon e tokens.
3. Definir **M0/M1** em histórias de usuário e critérios de aceite detalhados.
4. Montar monorepo, backend, banco, login, ambientes e CI/CD.
5. Criar os dois pacientes sintéticos e o primeiro fluxo vertical completo, antes de expandir telas.
6. Escolher instituição-piloto e responsáveis por segurança/regulação/validação clínica antes de qualquer dado real.

Nota de segurança: ONCOPHARMA é um projeto de software clínico em planejamento. Exemplos de medicamentos, protocolos e toxicidades neste documento ilustram requisitos de produto, não constituem orientação terapêutica para pacientes. A arte de marca escolhida é referência visual, ainda sem arquivo vetorial final e sem comprovação de registro.

ONCOPHARMA — Histórico das entregas técnicas

Compilação cronológica da documentação disponível dos marcos. Estes registros descrevem entregas e pendências; não equivalem à homologação clínica ou à validação de produção.

M0 — Fundação

Fonte: ONCOPHARMA_M0/README.md

ONCOPHARMA — Fundação M0

Produto em construção a partir do Plano Diretor v3.0 (2026-10-10). Duas experiências: Care (paciente/cuidador) e Clinical (equipe). Projeto preparado para evolução real, ainda sem operação clínica.

O que já existe

- Next.js + TypeScript: portal navegável /, /care, /clinical com marca SVG, responsividade e mensagens explícitas de indisponibilidade clínica.
- NestJS + TypeScript: GET /v1/health (liveness somente).
- Docker Compose para PostgreSQL de desenvolvimento (não conectado à API ainda).
- SQL inicial não homologado, ADRs, backlog e testes básicos.

Pré-requisitos

Node.js >=20, npm e, opcionalmente, Docker Desktop/Engine com Compose.

Iniciar localmente

```
npm install
npm run dev:portal
# outra janela:
npm run dev:api
```

Portal: http://localhost:3000 · API: http://localhost:4000/v1/health

Banco local opcional:

```
cp .env.example .env
# substitua a senha de exemplo por senha forte
# passe as variáveis do .env para o compose:
docker compose --env-file .env -f infra/compose.dev.yml up -d
```

Atenção: 0001_foundation.sql é apenas uma proposta inicial de schema; não é aplicado automaticamente. A API ainda não persiste dados. Não inserir informações reais de pacientes.

Testes

```
npm test
npm run build
```

npm test verifica invariantes iniciais. O build e os testes E2E precisam rodar em ambiente com dependências instaladas; não substituem auditoria de segurança nem validação clínica.

Estrutura

apps/portal/	Next.js, páginas Care/Clinical e identidade
services/api/	NestJS, endpoint de liveness
infra/	PostgreSQL local e SQL de fundação
packages/	Reservado a contratos e domínio compartilhado
docs/design/	Design system
docs/architecture/	Decisões de arquitetura
docs/product/	Backlog e critérios de aceite
tests/	Testes básicos do monorepo

Próximo marco M1

Identidade OIDC, MFA para profissionais, segregação institucional, RBAC+ABAC, auditoria, persistência, CI/CD e ambientes separados. Só depois habilitar endpoints de dados clínicos, sob revisão de segurança, privacidade e enquadramento regulatório.

Segurança

Nenhuma credencial real incluída. Nenhuma integração Tasy/MV/FHIR ativa. Nenhuma IA ativa. Nenhum paciente de teste criado ainda. Produção deve nascer vazia. NÃO usar esta versão para decisões assistenciais.

M1 — Fundação backend

Fonte: ONCOPHARMA_M1/README.md

ONCOPHARMA — Fundação M1 (evolução do M0)

Produto profissional em construção. Identidade e páginas Care/Clinical preservadas do M0. Ainda não apto a receber dados reais ou orientar assistência.

O que foi acrescentado

- PostgreSQL via pg, serviço NestJS e /v1/ready.
- Middleware OIDC JWT: valida assinatura via JWKS, iss, aud, expiração e sub.
- Rotas protegidas GET /v1/me e GET /v1/patients.
- Regra para /patients: ALLOW_SYNTHETIC_API=true, NODE_ENV != production, MFA, vínculo institucional e atribuição ativa do paciente; retorna somente pacientes sintéticos.
- Migração SQL com memberships, care_assignments, audit_events, RLS e trilha append-only.
- Seed idempotente de dois pacientes sintéticos, não executado automaticamente.

Requisitos

Node >=20, npm, PostgreSQL 17, psql, e provedor OIDC compatível com JWT de acesso e JWKS. Docker opcional; não incluído neste ambiente de entrega.

Instalação

```
npm install
cp .env.example .env
# Configure banco, OIDC_ISSUER, OIDC_AUDIENCE e OIDC_JWKS_URI com valores reais de DESENVOLVIMENTO.
# Exportar variáveis: set -a; source .env; set +a
npm run db:up            # requer Docker, opcional se PostgreSQL já estiver ativo
npm run db:migrate       # requer psql e DATABASE_URL
# Opcional: defina DEV_OIDC_SUB com sub de usuário de teste com MFA, depois:
npm run db:seed
npm run dev:api
npm run dev:portal
```

GET /v1/health é liveness, GET /v1/ready é prontidão do banco. GET /v1/me exige Bearer JWT. GET /v1/patients exige também header x-organization-id do laboratório (11111111-1111-4111-8111-111111111111) e habilitação explícita.

Não colar tokens ou senhas em chats, prints, arquivos versionados ou exemplos.

Testes

```
npm test
npm run test:m1
npm run build
```

Testes node --test são verificações estáticas de segurança, não substituem testes de integração ou auditoria. O build depende da instalação de pacotes. Neste ambiente de geração, a instalação offline não pôde ser concluída (pacotes ausentes no cache), portanto build e testes de integração não foram executados. Não há login visual completo nem integração hospitalar.

Arquitetura

- apps/portal: identidade visual e duas experiências (M0)
- services/api: validação JWT, PostgreSQL, guards, endpoints restritos (M1)
- infra/migrations: SQL; infra/seeds: dois pacientes sintéticos
- docs/product/STATUS-M1.md: limites e próximos critérios
- docs/architecture/ADR-003-m1-identidade-persistencia.md: decisões e riscos

Próximo marco

M1.1: integrar login OIDC Authorization Code + PKCE no portal; testes reais do PostgreSQL, autorização negativa, CI/CD e controle de segredos.

M1.1 — Autenticação

Fonte: ONCOPHARMA_M1_1/README_M1_1.md

ONCOPHARMA M1.1

Evolução incremental de M1, preservando M0, Care e Clinical.

Novidades

- Login OIDC Authorization Code + PKCE via Next.js Route Handlers.
- Sessão criptografada em cookie HttpOnly e BFF para API clínica.
- Página Clinical mostra estado da autenticação, MFA e pacientes sintéticos se liberados.

Configurar

1. npm install

2. Copiar .env.example para .env; configurar OIDC_ISSUER, OIDC_AUDIENCE, OIDC_JWKS_URI, OIDC_AUTHORIZATION_ENDPOINT, OIDC_TOKEN_ENDPOINT, OIDC_CLIENT_ID, SESSION_ENCRYPTION_KEY, PORTAL_ORIGIN, banco e credenciais de desenvolvimento.

3. Registrar redirect URI http://localhost:3000/api/auth/callback no provedor OIDC. Client público com PKCE obrigatório, sem client secret.

4. npm run db:up && npm run db:migrate; configurar vínculo de teste e opcionalmente npm run db:seed.

5. npm run dev:api e npm run dev:portal; acessar /clinical.

6. npm test; npm run build após instalar dependências.

Atenção: código preparado, não homologado, não executar com pacientes reais. Não versionar .env ou credenciais.

M1.2 — Banco e permissões

Fonte: ONCOPHARMA_M2_1/README_M1_2.md

ONCOPHARMA — M1.2: hardening de banco e validação integrada

Entrega real de código; integração ainda não executada neste ambiente. Não usar dados de pacientes reais.

O que mudou

- Role oncopharma_app com SELECT limitado e INSERT somente na auditoria; migrações e seeds usam DATABASE_URL_ADMIN.
- Scripts para provisionar credenciais de execução e resetar os dois pacientes sintéticos em DEV com confirmação explícita. A auditoria permanece.
- npm run doctor valida variáveis e separação de contas sem imprimir segredos.
- npm run test:db testa privilégios e isolamento RLS somente se houver PostgreSQL e psql disponíveis.
- Testes de código M1.2 incluídos no npm test.

Ordem de execução

1. Instale Node.js >=20, PostgreSQL 17 ou Docker e psql. npm install.
2. Copie .env.example para .env; defina senhas distintas e OIDC de desenvolvimento.
3. npm run db:up. Execute npm run db:migrate.
4. npm run db:provision-app com DATABASE_URL_ADMIN e APP_DB_PASSWORD.
5. Ajuste DATABASE_URL para o usuário oncopharma_app e sua senha.
6. npm run doctor; npm test; npm run test:db; npm run build.
7. Configure provedor OIDC real, MFA e vinculação DEV antes de habilitar ALLOW_SYNTHETIC_API=true.
8. Opcionalmente npm run db:seed com DEV_OIDC_SUB de teste.
9. Para remover registros sintéticos, com ambiente DEV e confirmação: CONFIRM_SYNTHETIC_RESET=APAGAR-TESTES-ONCOPHARMA npm run db:reset-synthetic.

Limites e pendências

- Sem Docker, psql, OIDC configurado ou rede de instalação de pacotes não é possível declarar teste integrado concluído.
- O reset não remove eventos de auditoria. Não é mecanismo de exclusão LGPD nem de migração para produção.
- Necessário criar papel operacional com migrações controladas, TLS do banco, backups, observabilidade, autenticação real de paciente e políticas de retenção.
- Acesso clínico real segue bloqueado; patients retorna apenas pacientes sintéticos vinculados.
- Testar CI e segurança com banco real antes de M2.

M2 — Núcleo clínico

Fonte: ONCOPHARMA_M2_1/README_M2.md

ONCOPHARMA M2 — Prontuário oncológico longitudinal (somente desenvolvimento)

Evolução cumulativa de M1.2. Não apto a dados reais nem assistência clínica.

Entregue

- Migração 0004_oncology_record.sql: protocolos versionados, ciclos e observações multiprofissionais, RLS por instituição.
- seed_m2_synthetic.sql: dois pacientes fictícios, ciclos FOLFOX e AC-T e relatos rastreáveis.
- GET /v1/patients/:patientId/record: OIDC, MFA, vínculo institucional, atribuição individual, RLS, auditoria e bloqueio em produção.
- Proxy autenticado do Next.js e interface Clinical para leitura da linha do tempo sintética.
- Limpeza de dados sintéticos ampliada para as tabelas M2.

Execução em ambiente de desenvolvimento

1. Configurar .env segundo .env.example e o README da M1.2. Instalar dependências: npm install.

2. Subir PostgreSQL: npm run db:up; configurar credenciais separadas e npm run db:provision-app.

3. Aplicar npm run db:migrate (0001 e 0002), provisionar role com npm run db:provision-app (0003), depois npm run db:migrate:m2 (0004) e npm run db:seed com OIDC_ISSUER e OIDC_SUB de um usuário de teste.

4. Habilitar ALLOW_SYNTHETIC_API=true e NEXT_PUBLIC_ALLOW_SYNTHETIC_UI=true apenas em DEV.

5. Iniciar API e portal; autenticar com provedor OIDC real configurado e MFA; abrir Clinical.

6. Executar npm test. Testes PostgreSQL requerem ambiente próprio e devem ser rodados separadamente.

Limites

Sem dados reais; sem persistência de novas evoluções via interface; sem cálculo de dose, sugestões terapêuticas, integração hospitalar ou IA. Exames laboratoriais e prescrições estruturadas serão modelados na próxima etapa. A auditoria deve ser complementada com política de retenção, segurança operacional e testes de intrusão antes de produção.

M2.1 — Prontuário estruturado

Fonte: ONCOPHARMA_M2_1/README_M2_1.md

ONCOPHARMA M2.1 — Prontuário clínico estruturado

Evolução incremental da M2; não usar com pacientes reais. Mantém autenticação OIDC/MFA, verificação de vínculo, RLS e auditoria existentes.

Novidades

- Migração infra/migrations/0005_structured_record.sql: alergias, medidas, laboratórios, ordens, administrações e avaliações farmacêuticas, com RLS por organização e grants apenas de leitura para a API.
- infra/seeds/seed_m2_1_synthetic.sql: registros fictícios para os dois pacientes de desenvolvimento.
- GET /v1/patients/:patientId/record: acrescenta structured, somente após autorização de profissional vinculado.
- Interface do prontuário: seis seções estruturadas e proveniência; sem recomendações ou automações.

Executar (após instalar/configurar a M2)

1. Configurar PostgreSQL, OIDC, variáveis .env e executar migrações/seeds anteriores seguindo README.md.

2. bash infra/scripts/migrate-m2-1-dev.sh com DATABASE_URL_ADMIN apontando somente para oncopharma_dev.

3. Iniciar API e portal conforme README da M2; habilitar apenas em DEV ALLOW_SYNTHETIC_API=true e NEXT_PUBLIC_ALLOW_SYNTHETIC_UI=true.

4. Entrar com identidade de teste previamente vinculada e MFA; abrir Clinical e selecionar paciente sintético.

Segurança e limites

- Não se permite acesso em NODE_ENV=production; sem prescrições ou administração via API; sem IA ativa.
- Prescrição e administração são tabelas distintas. Ausência de administração não significa não administração: pode haver registro externo ainda não integrado.
- Faixas laboratoriais ilustrativas não são referência clínica validada; unidades e códigos exigem terminologias e governança antes da homologação.
- Modelo preparado para mapeamento futuro a HL7 FHIR R4 (Observation, AllergyIntolerance, MedicationRequest, MedicationAdministration), não é um servidor FHIR nem possui conformidade certificada.
- Pendências: teste real de migração, build TypeScript/Next, teste E2E com PostgreSQL/OIDC, validação de conteúdo clínico, revisão LGPD e avaliação regulatória.

M2.2 a M8 — Consolidado

Fonte: ONCOPHARMA_Consolidado_M2_2_a_M8/README_CONSOLIDADO.md

ONCOPHARMA — pacote consolidado M2.2 até M8

Continuação da base M2.1, preservando Next.js/NestJS/PostgreSQL, identidade visual e arquitetura existente. Entrega em uma única versão: motor de regras somente sintético, esquema de workflows, contratos, documentação de IA, integrações e prontidão de piloto, além de uma prévia interativa offline que pode ser aberta no navegador.

Como testar agora

- Abra PREVIA_INTERATIVA.html no navegador. Tudo ali é fictício e permanece no navegador; não há API clínica conectada.
- Com Node.js >=20: npm run test:all (testes estruturais e unitários; banco e OIDC não testados).
- Para executar Next/Nest, siga README.md da base M2.1 e configure os serviços reais. Não habilite dados reais.

Limitações essenciais

Não estão completos operacionalmente: IA/RAG real, integrações FHIR/Tasy/MV, login do paciente, alertas entregues à equipe, notificação push, banco validado, testes E2E, homologação clínica/regulatória. O código de persistência do workflow é schema de leitura sem escrita pela API até revisão de segurança. Não confundir demonstração com software assistencial.

Arquivos principais

- PREVIA_INTERATIVA.html — fluxo navegável completo, sem dependências.
- packages/clinical-rules/src/index.mjs — regras determinísticas conservadoras, sem prescrição.
- infra/migrations/0006_clinical_workflow.sql — modelos clínicos, RLS e restrição DEV.
- packages/contracts/clinical-events.schema.json — eventos tipados.
- docs/product/ROADMAP_CONSOLIDADO.md — estado marco a marco.
- docs/quality/CRITERIOS_PILOTO_M8.md — checklist go/no-go.

M9 — Laboratório integrado

Fonte: ONCOPHARMA_Consolidado_M2_2_a_M8/README_INTEGRACAO_M9.md

ONCOPHARMA — M9: Primeiro fluxo integrado executável

Esta entrega acrescenta um laboratório local integrado ao projeto M2.2–M8. Ele conecta uma página Care/Clinical a uma API Node real com persistência local. Não substitui o backend NestJS nem as futuras integrações institucionais.

Comece por: npm run lab:dev e abra http://127.0.0.1:4177. Para testes, npm run test:lab. Consulte tools/synthetic-lab/README.md para limitações e segurança.

Fluxo: relato fictício → alerta determinístico → revisão simulada → intervenção → orientação em rascunho → auditoria. Não há autorização automática, IA clínica ou envio de mensagens.

Status de validação: teste HTTP automatizado incluído; testes de PostgreSQL, OIDC, Next/Nest e validação clínica permanecem pendentes. Uso exclusivamente educacional/DEV.

M10 — Integração

Fonte: ONCOPHARMA_M10_Integracao/README_M10.md

ONCOPHARMA — M10: integração NestJS/PostgreSQL (incremental)

Implementado em código

- services/api/src/workflow.controller.ts: relato Care autenticado, listagem de alertas Clinical, intervenção profissional.
- infra/migrations/0007_m10_patient_links.sql: vínculo OIDC do paciente, RLS e permissões limitadas do runtime.
- Cada gravação é transacional, com auditoria; relatórios são idempotentes por requestId UUID; todos os endpoints bloqueados em produção.
- Não há envio de orientação automática, nem diagnóstico ou triagem validada.

Rotas

- POST /v1/workflow/care/patients/:patientId/symptoms com { "symptomCode":"nausea", "description":"...", "requestId":"UUID" }
- GET /v1/workflow/clinical/patients/:patientId/alerts
- POST /v1/workflow/clinical/patients/:patientId/interventions com { "alertId":"UUID", "note":"...", "decision":"pending" }
- Todas requerem Authorization: Bearer <token> e x-organization-id: <UUID>.

Condições

ALLOW_SYNTHETIC_API=true em DEV, nunca em produção. Executar migrações com administrador e verificar permissões/RLS. Criar vínculos patient_portal_links somente com identidades de teste. Não usar dados reais.

Ainda pendente

OIDC real configurado, banco real, testes integrados, UI Care/Clinical conectada ao backend, revisão da política de auditoria, pipeline CI e homologação. Este pacote não é produção pronta.

M10.1 — Fluxo Web

Fonte: ONCOPHARMA_M10_1_Integrado/README_M10_1.md

ONCOPHARMA — M10.1 | Interface conectada ao fluxo M10

Implementação

- Care: formulário para relatar sintomas sintéticos ao endpoint protegido, com requestId único por envio.
- Clinical: listagem de alertas de pacientes fictícios atribuídos ao profissional, com registro de revisão pendente.
- BFF Next.js: encaminha requisições autenticadas à API NestJS sem expor bearer token ao browser. POST exige mesma origem, JSON e limite de corpo.
- O banco, auditoria e validação de autorização continuam sob responsabilidade do backend M10.

Como executar

1. Node.js >=20, PostgreSQL e provedor OIDC de teste configurados.

2. npm install, configurar .env conforme .env.example e executar migrações/seed de desenvolvimento conforme READMEs anteriores.

3. Em DEV, configurar ALLOW_SYNTHETIC_API=true, NEXT_PUBLIC_ALLOW_SYNTHETIC_UI=true, DEV_ORGANIZATION_ID=<uuid>, PORTAL_ORIGIN=http://localhost:3000 (ajustar à origem real), API_INTERNAL_URL=http://127.0.0.1:4000.

4. Iniciar API npm run dev:api e portal npm run dev:portal. Login deve ser efetuado com identidades OIDC de teste vinculadas no banco.

5. Executar npm run test:all e npm run test:m101.

Limites e riscos

- Não é sistema clínico validado. Nenhuma orientação ou alerta é transmitido automaticamente à equipe real.
- Os formulários estão bloqueados em produção; jamais usar dados reais ou credenciais reais para testes.
- A interface Care exige que o operador informe o UUID sintético; descoberta segura de paciente é trabalho futuro.
- As regras de febre/náusea são demonstrativas, não critérios clínicos aprovados.
- O fluxo não foi verificado contra PostgreSQL/OIDC reais neste ambiente; executar testes E2E e de segurança antes de qualquer piloto.
- Não há integração hospitalar, IA clínica ou envio de notificações.

ONCOPHARMA — Auditoria de aderência M10.2

Revisão do projeto M10.1 conforme o Plano Diretor v3.0 • 11 de outubro de 2026

Documento de reconciliação. O Plano Diretor v3.0 permanece como referência aprovada. Esta auditoria não modifica decisões D-001 a D-008.

1. Principais achados

Tema	Achado	Situação
Marca	SVGs tinham motivos simplificados; revisados com casa/família/coração e bolsa de infusão/profissional.	Correção parcial
Textos	Homepage mencionava M1; Care negava envio e Clinical negava conexão, apesar das rotas existentes.	Corrigido
Arquitetura	apps/portal único diverge de apps/care-web, clinical-web e admin-web previstos.	Pendente
Segurança	PostgreSQL, OIDC e isolamento não foram testados em execução integrada.	Pendente
Intelligence	IA clínica e RAG ainda não estão validados.	Pendente
Integrações	Tasy/MV/FHIR dependem de autorização institucional e implementação.	Pendente

2. Identidade visual: referência e limites

O Plano Diretor v3.0, página 1, apresenta a arte conceitual aprovada. Care combina casa, família e coração; Clinical combina bolsa de infusão e referência ao profissional. As cores aprovadas (#063F3B, #15735D, #0A344A, #D7A858, #B9E1D0) foram preservadas.

Os novos SVGs são interpretações vetoriais provisórias. Ainda precisam de comparação visual final, variantes de marca, favicon/splash e testes de acessibilidade. Não foi acrescentado símbolo ®.

3. Correções de software realizadas

- Textos de status atualizados em Home, Care e Clinical, sem prometer assistência real.
- SVG Care e Clinical revisados para refletir a direção da marca.
- Baseline integral v3.0 incluída em docs/product.
- Matriz de aderência e teste de regressão adicionados.

4. Testes e evidências

Executados 43 testes automatizados do repositório: 43 aprovados, 0 falhas. Seis deles foram criados especificamente para a reconciliação M10.2. Isso não comprova build completo, conexão real com PostgreSQL, autenticação OIDC, integração E2E, acessibilidade ou homologação clínica.

5. Próxima execução controlada

Prioridade: executar stack real de desenvolvimento; testar login, banco, políticas de acesso e fluxo Care → API → Clinical → auditoria. Em paralelo, finalizar arte vetorial fiel e preparar a separação arquitetural dos aplicativos sem quebrar rotas existentes.

6. Controle de versões

Plano Diretor v3.0 = baseline aprovada. Auditoria M10.2 = anexo de alinhamento. Não é uma alteração automática das decisões do plano. Uma futura v3.1 deverá incorporar somente mudanças explicitamente aprovadas.

ONCOPHARMA — CONSOLIDAÇÃO M10.3 A M14

Adendo técnico de execução e auditoria • 11 de outubro de 2026 • Base obrigatória: Plano Diretor v3.0

Conclusão executiva: os seis marcos foram trabalhados em uma entrega integrada de código, testes, documentação e governança. Nenhum marco foi declarado homologado. Uso assistencial com dados reais continua bloqueado.



Arte conceitual aprovada no planejamento; logotipos vetoriais definitivos permanecem pendentes.

1. Matriz de execução dos seis marcos

Marco	Entregue nesta consolidação	Estado
M10.3	Care/Clinical/Admin separados; identidade canônica e verificador	Parcial
M10.4	Roteiro E2E, workflow CI e gates de PostgreSQL/OIDC	Pendente validação
M11	Contrato de evidências, proveniência e bloqueio de autonomia	Parcial
M12	Adaptador FHIR R4 sintético, deduplicação e testes	Parcial
M13	Testes automatizados, rastreabilidade e critérios de segurança	Parcial
M14	Dossiê de piloto, responsabilidades e bloqueios	Pendente aprovação

2. Evidências de execução

Foram executados **49 testes existentes** e **15 testes novos**, todos aprovados. Também passaram a conferência de **15 arquivos visuais** entre as três aplicações e a verificação de presença dos documentos obrigatórios. Os testes são predominantemente unitários/estruturais; não comprovam integração clínica, implantação ou segurança completa.

3. Divergências do plano e correções

A divergência do aplicativo único foi tratada criando **apps/care-web**, **apps/clinical-web** e **apps/admin-web**. O portal legado foi mantido para regressão e deverá ser aposentado apenas após testes de paridade. A identidade visual passou a ter referência canônica em **packages/design-system**. Os SVG continuam provisórios, sem substituir a arte aprovada da página 1 do Plano Diretor.

4. Bloqueios ainda existentes

Sem Docker e sem provedor OIDC configurado no ambiente de construção, **não foram realizados** testes integrados reais com PostgreSQL, autenticação e MFA. Não há conexão autorizada com Tasy/MV. Não há IA clínica operacional, protocolos aprovados, validação regulatória SaMD, instituição-piloto, equipe de monitoramento, SLAs ou aceite assistencial. Nenhum dado real deve ser inserido.

5. Critérios de passagem obrigatórios

G01 arquitetura e identidade; G02 banco e isolamento multi-instituição; G03 autenticação e MFA; G04 regras clínicas aprovadas; G05 validação de IA; G06 integração autorizada; G07 LGPD, segurança e acessibilidade; G08 avaliação regulatória, instituição e equipe; G09 aprovações formais. Consulte **docs/quality/PILOTO_GATES.md** no pacote.

6. Referência e controle de mudanças

O Plano Diretor v3.0 permanece a baseline. O documento **PLANO_DIRETOR_V3_1_ADENDO.md** é um adendo técnico proposto, não uma substituição ou aprovação automática de mudanças. Cada evolução requer rastreabilidade requisito → implementação → teste → aceite. Código presente não equivale a função homologada.

Arquivos entregues: ZIP do repositório consolidado, relatório individual e PDF histórico cumulativo.

ONCOPHARMA | Relatório técnico M14.1

Adendo ao Plano Diretor v3.0 — fechamento de pendências verificáveis e prevenção de liberação indevida.

1. Base e controle de mudanças

Código M10.3–M14 preservado. Nenhuma decisão D-001 a D-008 foi alterada. Identidade Care/Clinical mantida; texto de ambiente atualizado para M14.1 DEV SINTÉTICO.

2. Correções efetivas

O comando de build principal passa a compilar Care, Clinical, Admin e API. CI instala dependências e executa build e testes de prontidão. Adicionado verificador de evidências G01–G09 com bloqueio por padrão.

3. Testes realmente executados

npm test, test:extended, test:readiness, check:design e check:governance concluíram com código de saída zero. Os quatro novos testes do gate passaram. O gate de liberação retornou código 1, corretamente bloqueando a liberação por falta de aprovações.

4. Pendências e limitações

npm install offline falhou por dependências não disponíveis no cache. Não foi executado build Next.js/NestJS, nem PostgreSQL, migrações, isolamento RLS, login OIDC/MFA ou teste E2E com navegador. Não há validação clínica ou autorização institucional.

5. Próxima decisão de engenharia

Executar o monorepo em ambiente DEV com rede para instalar dependências, PostgreSQL, IdP OIDC e testes E2E. Reunir evidências assinadas e avaliações clínicas/regulatórias para cada gate. Produção e piloto permanecem bloqueados.

STATUS: ENTREGA TÉCNICA PARCIAL — NÃO HOMOLOGADA PARA USO ASSISTENCIAL.

ONCOPHARMA | Relatório M14.2

Base normativa: Plano Diretor v3.0, decisões D-001 a D-008. Continuação do histórico acumulado até M14.1.

Objetivo: reduzir pendências técnicas verificáveis sem declarar homologação indevida.

Resultados comprovados nesta execução

Verificação	Resultado
Testes locais de código (npm test)	54 aprovados / 0 falhas
Testes estendidos	15 aprovados / 0 falhas
Teste HTTP de fluxo sintético M14.2	1 aprovado / 0 falhas
Gate de liberação	4 testes aprovados; liberação bloqueada
Identidade visual e governança	Verificadores executados e aprovados
PostgreSQL obrigatório	BLOQUEADO: DATABASE_URL ausente
Build Next.js/NestJS	NÃO VALIDADO: dependências indisponíveis
OIDC/MFA real	NÃO VALIDADO: provedor ausente
Piloto assistencial	NÃO AUTORIZADO

Correções efetivamente implementadas

1. Novo teste de fluxo HTTP ponta a ponta do laboratório sintético: relatório, alerta, revisão, rascunho de orientação, trilha de auditoria e reset. Inclui bloqueios para paciente não sintético, origem indevida e revisão duplicada.

2. Pré-condição obrigatória para testes PostgreSQL: sem DATABASE_URL, cliente psql ou conexão válida, o processo encerra com erro; não confunde testes ignorados com sucesso.

3. Scripts de migração e carga sintética protegidos contra NODE_ENV=production e contra execução em banco diferente de oncopharma_dev.

4. Pipeline de integração contínua alterada para exigir a pré-condição de banco antes dos testes PostgreSQL.

Pendências não resolvíveis apenas com código local

Instalação de dependências e build real, PostgreSQL com papéis e RLS validados, provedor OIDC/MFA, teste em navegador das interfaces reais, avaliação clínica das regras, segurança/LGPD, enquadramento regulatório e instituição-piloto.

Decisão: não autorizar dados reais, prescrição automatizada, monitoramento assistencial ou piloto. Identidade Care/Clinical preservada sem redefinição de marca.

Próximo critério de saída: execução reprodutível em infraestrutura com banco e identidade, com evidências anexadas e revisão independente.

ONCOPHARMA | Relatório de correções M14.3

Referência vinculante: Plano Diretor v3.0, decisões D-001 a D-008. Data: 11/10/2026. Ambiente: desenvolvimento sintético.

Correções realizadas e rastreáveis

Área	Constatação	Correção
CI/PostgreSQL	Banco oncopharma_ci divergia das migrações	Banco efêmero oncopharma_dev
Controle de acesso	Testes usavam credenciais administrativas	Provisionamento e teste como oncopharma_app
Auditoria	Sem política RLS de INSERT na tabela	Política de inserção limitada por organização
Testes	Pré-requisito não exigia role restrita	Falha fechada para role incorreta
Regressão	Risco de repetir falhas no pipeline	Cinco testes estáticos adicionados

Evidências executadas

• 5/5 testes novos de regressão aprovados.

• npm run verify:local: aprovado (testes de código, design e governança).

• npm run test:db:required: bloqueado corretamente (sem DATABASE_URL).

• npm run quality:gate: bloqueado corretamente (sem aprovações e evidências).

• npm install --offline: indisponível (pacotes ausentes do cache npm).

Pendências que continuam abertas

• Build Next.js/NestJS com dependências instaladas e teste de interface no navegador.

• Migrações PostgreSQL e políticas RLS executadas de fato em banco real de desenvolvimento.

• OIDC/MFA com provedor autorizado e identidades fictícias; testes de autorização multi-institucional.

• Revisão clínica das regras e evidências; avaliações LGPD/SaMD; instituição e responsáveis pelo piloto.

Conclusão: correções de configuração, SQL e testes entregues em código. Integração real e liberação assistencial NÃO homologadas. Identidade visual e planejamento anteriores preservados.

ONCOPHARMA | Relatório de validação M14.4

Referência: Plano Diretor v3.0 e histórico acumulado até M14.3. Dados exclusivamente sintéticos. Nenhuma liberação assistencial.

Execução realizada

Foram executadas as suítes locais e o laboratório HTTP com Node.js 22. O relatório JSON e os logs correspondentes estão incluídos no projeto. A tentativa de instalar dependências npm não terminou dentro do tempo disponível; não houve compilação Next.js/NestJS.

Verificação	Estado	Evidência / limitação
local-tests	PASS	59 + 15 + 1 + 4 + 1 testes nas suítes do comando verify:local; verificar logs.
lab-unit-tests	PASS	1 teste HTTP sintético passou.
postgres-required	BLOCKED	DATABASE_URL não configurada; sem serviço PostgreSQL.
full-build	BLOCKED	Next.js e NestJS não instalados.
oidc-mfa	BLOCKED	Provedor institucional e MFA não configurados.
browser-lab-render	BLOCKED	Chromium não concluiu renderização no ambiente.

Correções e governança

Foi criado o comando npm run validate:evidence, que registra PASS, FAIL ou BLOCKED sem converter ausência de infraestrutura em sucesso. O pipeline CI recebeu teste HTTP sintético e exportação de evidências. Identidade Care/Clinical e arquivos de aplicação foram preservados, sem alterações visuais nesta versão.

Condições obrigatórias para conclusão

1. Instalar dependências e concluir build dos três aplicativos e da API. 2. Executar migrações e testes RLS no PostgreSQL com role restrita. 3. Configurar OIDC/MFA de homologação e testar acesso por papel. 4. Executar E2E real Care → API → Clinical no navegador. 5. Obter avaliação clínica, LGPD/SaMD e autorização institucional antes de qualquer piloto.

Decisão de liberação: BLOQUEADA. Nenhum dado real, nenhuma prescrição automática e nenhum uso assistencial.

ONCOPHARMA

M14.5 - Validação técnica

Care + Clinical | Continuidade do Plano Diretor v3

NO-GO para piloto integrado e uso assistencial

A compilação e verificações locais avançaram. O PostgreSQL 17 não pode iniciar neste container. O fluxo persistido, RLS e autorização institucional permanecem bloqueados. Nenhuma aprovação clínica foi emitida.

Rodada: 2026-10-11T18:59:32.152Z até 2026-10-11T19:02:57.997Z.

Checks: 13 PASS, 0 FAIL, 5 BLOCKED.

Decisões D-001 a D-008 e identidade ONCOPHARMA, Care e Clinical preservadas.

Fonte: validation-report.json e logs/capturas incluídos no ZIP.

Resultado por grupo

Verificação	Estado	Escopo / limite
node22	PASS	v22.23.3
lockfile	PASS	npm ci requires the committed lockfile.
local-tests	PASS	Comando executado; consulte log e exit code.
lab-unit-tests	PASS	Comando executado; consulte log e exit code.
clinical-rules	PASS	Comando executado; consulte log e exit code.
full-build	PASS	Comando executado; consulte log e exit code.
api-security-unit	PASS	Comando executado; consulte log e exit code.
design	PASS	Comando executado; consulte log e exit code.
governance	PASS	Comando executado; consulte log e exit code.
release-gate-enforced	PASS	Comando executado; consulte log e exit code.
clinical-release	BLOCKED	G01-G09 require external approvals; readyForClinicalUse remains false.
postgres-required	BLOCKED	PostgreSQL 17.10 obtained, but initdb refuses UID 0; uid_map exposes only UID 0, runuser fails with Operation not permitted, unshare UID mapping is forbidden, and Docker is absent. Bootstrap and required tests return exit 2 (connection refused); no DB integration executed.
migration-0003	BLOCKED	Static call confirmed in provision-app-role.sh. Database execution not proven.
browser-surfaces	PASS	Actual Playwright results: 4/4 passed.
oidc-core	PASS	Actual Playwright results: 8/8 passed. Local identity is separate from institutional RBAC.
oidc-mfa	BLOCKED	Core identity may pass independently; institutional RBAC/ABAC and patient links need real PostgreSQL integration.
vertical-care-clinical-audit	BLOCKED	No simulated persistence or authentication. PostgreSQL prerequisite blocked.
source-stability	PASS	Source digest unchanged throughout the validation.

O que foi corrigido

- Node 22, package-lock e npm ci; secrets do CI em variáveis.

- Client directive e tipo de alerta corrigidos; portal legado preservado.

- Rótulo Clinical passa a usar navy aprovado para atender contraste. Tokens e logotipos preservados.

- Atribuições profissionais consultadas em contexto de tenant. API e runner recusam superusuário/BYPASSRLS.

- Callback valida JWT/ID token, nonce, issuer, audience e expiração. Admin tem apenas infraestrutura de sessão.

- Healthchecks; testes Playwright/axe; Keycloak local de teste com seis contas sintéticas e TOTP real.

PostgreSQL: bloqueio confirmado

Binário PostgreSQL 17.10 obtido. initdb: cannot be run as root. O namespace mapeia somente UID 0; runuser: cannot set groups: Operation not permitted. Remapeamento de UID por unshare não permitido. Docker ausente. psql 16.15 foi executado. Bootstrap e teste obrigatório retornaram exit 2 por conexão recusada.

A migração 0003 é chamada pelo provisionamento; execução no banco não comprovada. Testes de dois tenants, INSERT de auditoria e elevação de privilégios preparados, sem resultados integrados. Superusuário pode contornar RLS no PostgreSQL; o controle é sua recusa no runtime.

Evidência de navegador e identidade

Capturas em celular, tablet e desktop; teclado e axe. O núcleo de identidade verifica TOTP, PKCE, assinatura, cookie HttpOnly, estado inválido, CSRF, JWT adulterado e expiração. Isso não valida RBAC/ABAC, vínculo de paciente ou persistência institucional.

Logout validado é local à aplicação. Logout global/revogação do IdP e sessão Secure em HTTPS de homologação permanecem sem prova. O Admin não ganhou operações administrativas.

Tentativas e transparência

Download padrão Chromium inválido; alternativa Chromium 153 utilizada sem desativar a segurança web. Uma rodada foi invalidada por npm ci durante testes e repetida sequencialmente. Erros anteriores permanecem nos logs; o JSON final distingue PASS, FAIL e BLOCKED.

Riscos e próximos critérios de saída

- Executar PostgreSQL 17 em ambiente efêmero com usuário não-root, migrações 0001 a 0007, role restrita e testes negativos.

- Executar o fluxo real Care -> PostgreSQL -> Clinical -> intervenção -> auditoria, incluindo patientId de outro paciente e autorização por papel.

- Validar idempotência/rollback/restauração, concorrência, autorização institucional e logout global.

- Executar CI com secrets e infraestrutura de identidade/navegador; nenhum GitHub Actions foi executado nesta entrega.

- Ampliar acessibilidade e PWA/offline; avaliar leitores de tela, zoom 200%, usabilidade e falhas de comunicação.

- Obter responsáveis clínicos, operação de alertas/SLA, privacidade/LGPD, enquadramento regulatório e aprovações G01-G09.

Decisão técnica

NO-GO para piloto integrado, produção e uso assistencial. GO apenas para continuar desenvolvimento e validação sintética isolada. readyForClinicalUse=false e clinicalApproval=false. Nenhuma prescrição, alteração de dose ou liberação de ciclo automática.

Integridade e rastreabilidade

SHA-256 do baseline M14.4:
e8c492bbe9f2101a8cf56acc6d801ce790f25642a3dabee09f4f11432a49396d
Digest das fontes validadas:
4ad867aebc22a4bfb3de8771ea1cfbb70034fbfb786697ade1559661eab4dc4a
Documentos entregues: README_M14_5.md, changelog, lista de arquivos alterados, matriz atualizada, diff, logs, capturas e JSON. Consulte-os para comandos completos e limitações por requisito.

O PDF acumulado mantém todas as 37 páginas da M14.4 e acrescenta estas páginas como revisão M14.5. Os estados antigos permanecem históricos, não descrevem a rodada atual.

ONCOPHARMA — Relatório M14.5

Validação integrada técnica em DEV sintético · 11/10/2026 · branch fix/m14-5

> **Não homologado para uso assistencial.** Somente pacientes e contas sintéticos. Piloto: NO-GO. Uso clínico: NÃO.

Resultado do validate:evidence (release M14.5)

Check	Estado	Observação
local-tests	**PASS**	exit 0
lab-unit-tests	**PASS**	exit 0
postgres-required	**PASS**	exit 0
full-build	**PASS**	exit 0
e2e-care-clinical	**PASS**	exit 0
oidc-mfa-test-idp	**PASS**	OIDC code+PKCE, TOTP real, claim amr, audience, sessão HttpOnly, CSRF, logout RP-initiated, expiração e negativos de papel validados no navegador e na API contra IdP de TESTE local (Keycloak dev) com
oidc-mfa	**BLOCKED**	IdP de homologação institucional não definido (D-008). A validação M14.5 usou somente IdP de teste local; repetir a suíte no IdP escolhido antes de qualquer piloto.
release-gate	**BLOCKED**	Gate de piloto/produção: bloqueado até aprovações formais (esperado).
browser-lab-render	**PASS**	exit 0

readyForIntegratedValidation = false · readyForClinicalUse = false · clinicalApproval = false

Correções de causa-raiz

- Build: 'use client' fora da 1ª linha em ClinicalAccess (clinical-web/portal) e tipo Alert sem rule_version (care-web).
- API: parâmetros não tipados em jsonb_build_object causavam erro 500 no PostgreSQL ao auditar.
- API: checkStaff consultava care_assignments (FORCE RLS) sem contexto de tenant → todo profissional era negado.
- Care: callback de login redirecionava para /clinical (404); adicionados Entrar/Encerrar sessão.
- Proxy: negações exibidas como 'Forbidden'; agora mensagem pt-BR da API.
- Clinical: confirmação de revisão era apagada imediatamente.
- Acessibilidade: contraste 3,45:1 no rótulo 'AMBIENTE PROFISSIONAL' → 4,75:1 (tokens de marca inalterados).
- Segurança: logout RP-initiated opcional (OIDC_END_SESSION_ENDPOINT) encerra a sessão SSO.

Evidências principais

- PostgreSQL 17, role oncopharma_app: 9/9 testes (RLS entre instituições, patientId do cliente, auditoria append-only, bypass de superusuário).
- E2E Playwright + Chrome: 9/9 — Care → API/PostgreSQL → Clinical → intervenção → auditoria; OIDC+PKCE, TOTP real, negativos de papel/MFA, CSRF, logout, expiração real de token; axe WCAG A/AA sem violações sérias.
- IdP usado: Keycloak 26.8 local em modo de TESTE (não é o IdP institucional).

Bloqueios e decisões pendentes

- oidc-mfa institucional: IdP de homologação não definido (D-008).
- Hospedagem/região, instituição-piloto, operação de alertas/SLA (D-008).
- Gate G01–G09: aprovações clínica, LGPD/RIPD, SaMD/Anvisa.
- Aprovar/reverter ajuste de contraste e links de login no Care; destino do apps/portal; modelo do cuidador; seleção do paciente no Care.
- Executar o CI em repositório remoto.

Detalhes: README_M14_5.md, CHANGELOG_M14_5.md, docs/product/MATRIZ_RASTREABILIDADE.md, artifacts/validation/.

ONCOPHARMA — Relatório M14.5 CONSOLIDADO

Grok Bot + proposta independente Codex · 11/10/2026 · branch fix/m14-5-merge (commit base fix/m14-5)

> **Não homologado para uso assistencial.** Somente pacientes e contas sintéticos. Piloto: NO-GO. Uso clínico: NÃO.

Resultado do validate:evidence — 18 PASS · 0 FAIL · 2 BLOCKED

Check	Estado	Observação
node22	**PASS**	v22.23.3
lockfile	**PASS**	package-lock.json versionado (CI usa npm ci).
local-tests	**PASS**	exit 0
lab-unit-tests	**PASS**	exit 0
clinical-rules	**PASS**	exit 0
postgres-required	**PASS**	exit 0
migration-0003	**PASS**	Aplicada por provision-app-role.sh (bootstrap); GRANTs e política INSERT de audit_events exercitados no PostgreSQL.
migration-0008-nullif	**PASS**	Políticas com nullif; sessão reutilizada retorna 0 linhas sem erro 22P02 (tests/m145-db-0008.integration.mjs).
full-build	**PASS**	exit 0
api-security-unit	**PASS**	exit 0
design	**PASS**	exit 0
governance	**PASS**	exit 0
e2e-care-clinical	**PASS**	(node:333275) Warning: The 'NO_COLOR' env is ignored due to the 'FORCE_COLOR' env being set. (Use `node --trace-warnings ...` to show where the warning was created)
oidc-mfa-test-idp	**PASS**	OIDC code+PKCE, TOTP real, claim amr, audience, sessão HttpOnly, CSRF, logout RP-initiated, expiração e negativos de papel validados no navegador e na API contra IdP de T
vertical-care-clinical-audit	**PASS**	Care -> API/PostgreSQL -> Clinical -> intervenção -> auditoria com pacientes sintéticos, isolamento por organização e role restrita.
oidc-mfa	**BLOCKED**	IdP de homologação institucional não definido (D-008). A validação M14.5 usou somente IdP de teste local; repetir a suíte no IdP escolhido antes de qualquer piloto.
release-gate-enforced	**PASS**	quality:gate sai com 1 e bloqueia G01–G09 (comportamento esperado).
clinical-release	**BLOCKED**	G01–G09 exigem aprovações externas (clínica, LGPD/RIPD, SaMD/Anvisa, instituição, operação de alertas).
browser-lab-render	**PASS**	/usr/bin/google-chrome renderizou laboratório sintético (o E2E dos apps é o check e2e-care-clinical).
source-stability	**PASS**	Fontes inalteradas durante a validação.

readyForIntegratedValidation=false · readyForClinicalUse=false · digest de fontes 452ef050c27aac8f... (estável)

Incorporado da proposta Codex

- Callback OIDC valida id_token e access token por JWKS (iss, aud, exp, nonce, at_hash, sub); fecha o risco R6.
- Destino pós-login restrito a caminho local (padrão /care mantido no Care).
- API recusa superusuário/BYPASSRLS/role diferente de oncopharma_app; role runtime NOSUPERUSER/NOCREATEDB/NOCREATEROLE; pré-requisito de teste recusa role privilegiada.
- checkStaff em uma transação com tenant (forma Codex, equivalente à minha correção).
- Testes: m145-api.security (2), m145-db (executado aqui pela 1ª vez: PASS); ideias E2E portadas (OTP incorreto, cookie inacessível ao JS, nonce, state inválido, verifier PKCE incorreto, 390/768/1440 px, envio sem sessão).
- CI com npm ci, test:api:security, test:rules e senhas via secrets; healthchecks /api/health; workspaces packages/*, build inclui clinical-rules e portal; validate:evidence v2 (logs sanitizados, digest de fontes).

Conflitos resolvidos

Tema	Grok × Codex	Mantido / motivo
Contraste do rótulo Clinical	#8b642d (Grok) × navy (Codex)	Grok: mantém o acento dourado aprovado; nenhum token alterado; aguarda aprovação (R9)
Destino pós-login Care	/care fixo × postLoginPath padrão /clinical	Combinação: validação Codex + padrão /care
checkStaff fora do tenant	só atribuição × ambas na mesma transação	Codex: equivalente e com teste unitário
Harness E2E	PostgreSQL real + Keycloak 26.8 × H2 sem banco	Grok: único que executa o fluxo vertical persistido
Senhas do Postgres no CI	literais de teste × secrets	Codex: higiene

Não incorporado

- Sessão no admin-web (sem operações administrativas; amplia superfície).
- .gitignore do Codex removia *.log, coverage/ e dados locais do laboratório.
- Perda do bit executável dos scripts; harness e2e-real/run-identity-validation (redundante e dependente do container Codex); evidências do ambiente Codex.

Novo: migração 0008 (R1)

ALTER POLICY nas 11 políticas de 0006/0007 para nullif(current_setting('app.organization_id',true),'')::uuid. Antes: sessão reutilizada gerava erro 22P02 em clinical_alerts e patient_portal_links. Depois: zero linhas, INSERT sem contexto continua negado. Teste vermelho→verde (tests/m145-db-0008.integration.mjs). Não amplia acesso.

Pendências do responsável

1) IdP institucional e política de MFA (D-008); 2) hospedagem/região; 3) repositório remoto + secrets ONCO_CI_DB_ADMIN_PASSWORD/ONCO_CI_DB_APP_PASSWORD para rodar o CI; 4) aprovar ou reverter o ajuste de cor (R9); 5) destino do apps/portal; 6) modelo do cuidador e seleção do paciente no Care; 7) aprovações G01–G09 para qualquer piloto.